Sistema de Gestión y Análisis de Identidades en AWS bajo una Arquitectura Zero-Trust: Auditoría Continua e IA Heurística

Trabajo Fin de Grado

Grado en Ingeniería de la Ciberseguridad

Autor: *José Jesús Peñate Perdomo*

Tutor: *César Cáceres Taladriz*

Universidad Rey Juan Carlos | Escuela Técnica Superior Ingeniería Informática

Índice

1. Contexto y Objetivos
2. Metodología y Arquitectura
3. Implementación y Seguridad
4. Observabilidad y Detección
5. Validación Experimental
6. Conclusiones

Motivación y Contexto

- **Contexto:** Las plataformas FinTech gestionan información financiera sensible y están sujetas a estrictos requisitos de seguridad, auditoría y trazabilidad.
- **Limitación del modelo tradicional:** En arquitecturas cloud distribuidas, la seguridad perimetral y la confianza implícita dentro de la red resultan insuficientes para detectar accesos indebidos, abusos de privilegios o comportamientos anómalos.
- **Necesidad técnica:** Es imprescindible adoptar un modelo de seguridad que no confíe por defecto, registre cada acción y permita analizar la actividad de forma continua y centralizada.
- **Enfoque del proyecto:** Diseño de una infraestructura en AWS para *CloudFinance S.L.* basada en **Zero Trust**, observabilidad avanzada y detección proactiva de amenazas.

Objetivo General del TFG

Objetivo General

Diseñar, desplegar y validar una arquitectura cloud segura y resiliente en AWS, alineada con el **AWS Well-Architected Framework** (Pilar de Seguridad), incorporando principios de **Zero Trust**, observabilidad avanzada y detección proactiva de amenazas.

Objetivos Específicos del TFG

Fundamentos de Seguridad Cloud:

- **Gestión de Identidades y Accesos (IAM):** Implementar control de acceso granular basado en roles, aplicando el principio de *Least Privilege* y autenticación multifactor (MFA) entre otros pérmisos.
- **Protección de Datos Sensibles:** Garantizar la confidencialidad e integridad de la información mediante cifrado en tránsito y en reposo utilizando AWS KMS y AES-256.

Objetivos Específicos del TFG

Observabilidad, Detección y Validación:

- **Auditoría y Observabilidad:** Centralizar y correlacionar eventos de seguridad mediante CloudTrail, CloudWatch y un sistema de alertas avanzado.
- **Análisis Inteligente de Amenazas:** Transformar registros de infraestructura en inteligencia de seguridad accionable mediante consultas avanzadas en **Amazon Athena** y lógica heurística de detección.
- **Validación Experimental:** Evaluar la eficacia de la arquitectura mediante experimentos controlados que simulan accesos no autorizados y comportamientos anómalos.

Metodología de Trabajo

Se ha seguido un **enfoque iterativo e incremental**, alineado con las mejores prácticas de ingeniería y seguridad en la nube:

- **Fase 1 - Diseño y Modelado:** Definición de la arquitectura base fundamentada en el pilar de seguridad del **AWS Well-Architected Framework** y modelos *Zero Trust*.
- **Fase 2 - Despliegue Progresivo:** Implementación por capas (Red, Identidad, Cómputo y Datos) aplicando el principio de mínimo privilegio en cada iteración.
- **Fase 3 - Desarrollo y Analítica:** Integración del *backend* y configuración del módulo de detección heurística mediante Amazon Athena.
- **Fase 4 - Validación Continua:** Ejecución de simulaciones de ataque, revisión de métricas y ajuste (*tuning*) de políticas y alertas.

Arquitectura de Alto Nivel (visión)

- **Capa Edge:** CloudFront como entrada global y superficie controlada.
- **Capa Origen:** ALB como terminación TLS y distribución de tráfico hacia EC2.
- **Capa App:** backend en EC2 (Nginx/Gunicorn/Flask), aislado del exterior.
- **Datos:** S3 cifrado con KMS y RDS con controles de acceso basados en IAM.
- **Observabilidad:** CloudTrail/CloudWatch + logs centralizados en S3 para analítica y detección.

Idea clave

Separación de responsabilidades + mínimo privilegio + trazabilidad completa.

Zero Trust aplicado en la arquitectura

- **Verificar explícitamente:** MFA obligatorio, políticas con condiciones (IP/servicio/región).
- **Mínimo privilegio:** roles por función (App, Finanzas, Analista, Admin) y permisos acotados.

Resultado

Controles de identidad + controles criptográficos + observabilidad para reducir superficie de ataque y mejorar respuesta.

Control de Accesos con IAM (Roles)

Diseño por perfiles y segregación de funciones:

- **EC2-App-Role:** acceso a S3 y KMS *solo* a prefijos necesarios (sin credenciales estáticas).
- **Analista-Datos:** solo lectura en S3 + CloudTrail/CloudWatch para auditoría (MFA + restricciones) y análisis mediante el módulo heurístico.
- **Finanzas-Lectura:** lectura acotada a informes y consultas permitidas (sin modificar datos).
- **Admin-ti:** permisos elevados pero con **denegaciones** si no hay MFA / fuera de región.

Valor

Menos exposición, mayor control y trazabilidad de acciones.

Protección de Datos: KMS, S3 y RDS

- **S3 + SSE-KMS:** cifrado en reposo con políticas que fuerzan:
  - transporte seguro (HTTPS),
  - cifrado obligatorio,
  - uso de la *clave KMS correcta*.
- **RDS + IAM:** autenticación basada en credenciales temporales, evitando contraseñas persistentes.
- **Defensa en profundidad:** control a nivel IAM + control criptográfico + control a nivel base de datos.
- **Asumir brecha:** cifrado KMS + logs inmutables/centralizados + detección temprana.

Auditoría y Monitorización (CloudTrail + CloudWatch)

- **CloudTrail:** registro de eventos administrativos y cambios en recursos (auditoría forense).
- **CloudWatch Logs:** centraliza eventos y permite métricas/alertas sobre patrones críticos.
- **Alarmas + SNS:** notificación inmediata ante *AccessDenied* / *UnauthorizedOperation* o 5XX.

Valor para ciberseguridad

Reduce MTTR y permite respuesta proactiva ante abuso de permisos o fallos de disponibilidad.

SOC Cloud: Dashboard Unificado y Alarmas Inteligentes

- **Alarma condicional en CloudFront:** se evalúa 5xxErrorRate solo si el volumen de requests supera un umbral.
- **Dashboard unificado:** correlación Edge → Origen:
  - Requests y 5xxErrorRate (CloudFront),
  - RequestCount y Target 5XX (ALB/Targets),
  - Latencia **p90** (tail latency) como indicador temprano de saturación.

Mensaje clave

Menos falsos positivos, mejor contexto operacional y capacidad real de monitorizar como un SOC.

Análisis Inteligente con Athena (Logs → Inteligencia)

- **Data Lake en S3:** logs de CloudFront/ALB/CloudTrail centralizados por prefijos.
- **Athena:** tablas externas para consultar logs como SQL (sin servidores).
- **Separación de salidas:** resultados en /athena/ y reportes de seguridad en /informes/seguridad/ (KMS).

Valor

Permite análisis forense rápido y escalable, y sirve de base para el módulo de detección.

Módulo de Detección Heurística (Modelo Explicable)

- **Integración en backend:** micro-módulo Python consulta Athena bajo demanda.
- **Modelo explicable:** cálculo de *RiskScore* por IP con señales:
  - tasa de peticiones (RPS),
  - errores 4xx (fuzzing / enumeración),
  - diversidad de URIs y patrones anómalos.
- **Salida operativa:** generación automática de CSV cifrado (KMS) con IPs marcadas.

Mensaje clave

No es "caja negra": cada alerta se justifica por métricas observables.

Validación Experimental (qué se demostró)

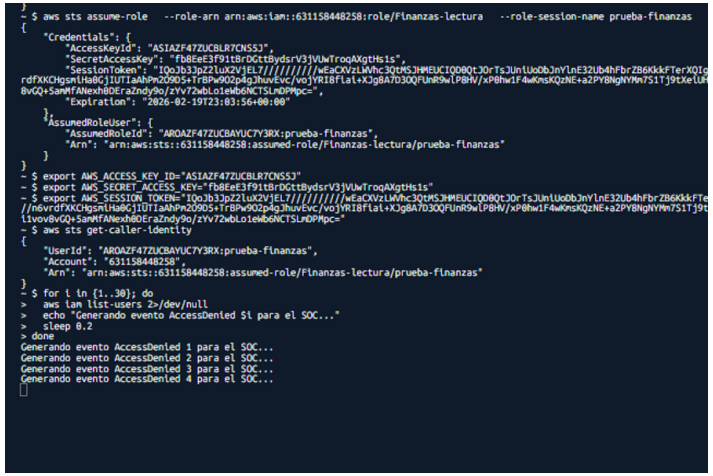
Pruebas controladas para verificar seguridad y trazabilidad:

- **Acceso sin MFA / permisos insuficientes:** se verifica denegación y registro en CloudTrail.
- **Intentos de acceso fuera de condiciones (IP/región):** políticas condicionadas funcionan.
- **Errores 5XX y degradación:** alarmas y dashboard detectan fallo (ALB / Targets).
- **Ataque simulado (enumeración/fuzzing):** incremento 4xx y activación de análisis en Athena.

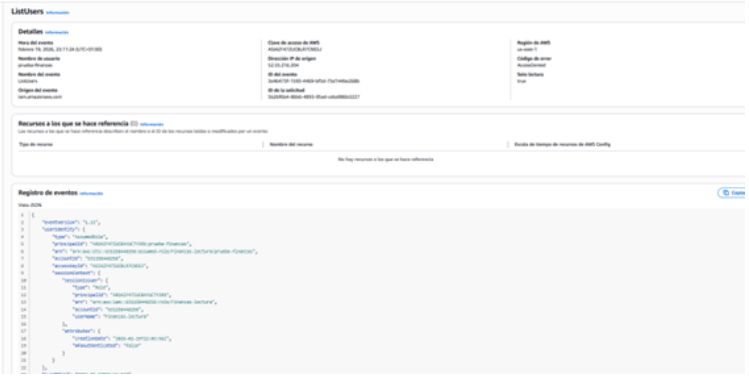
Resultado

Evidencia de trazabilidad end-to-end y detección operacional con alertas accionables.

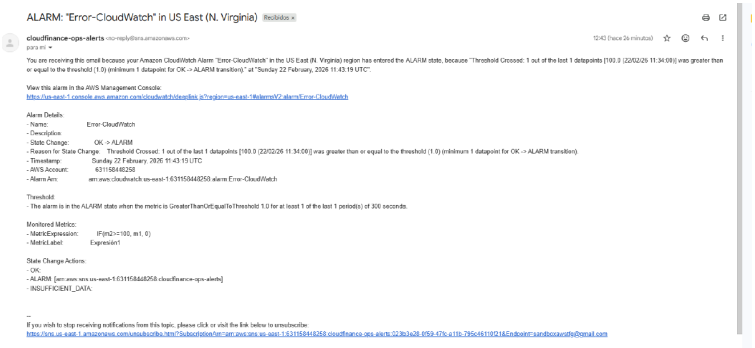
Evidencias de funcionamiento (I)



(a) Simulación de ataque: Bloqueo por Mínimo Privilegio



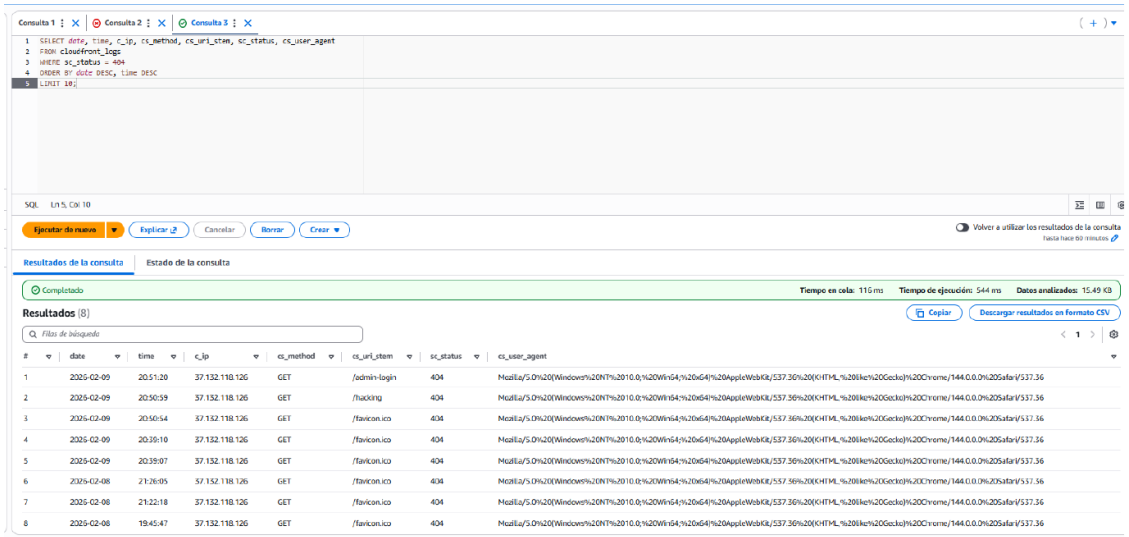
(b) Trazabilidad: Log en CloudTrail



(c) Respuesta: Alerta vía SNS

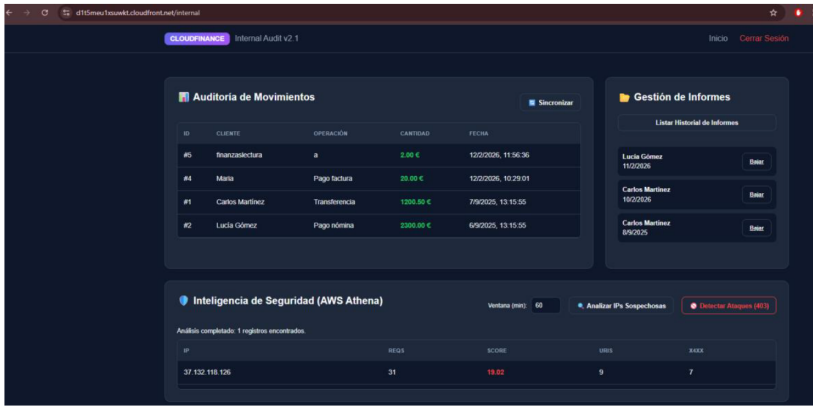
Evidencias de funcionamiento (II): SOC y Analítica

(a) Dashboard Unificado del SOC en CloudWatch

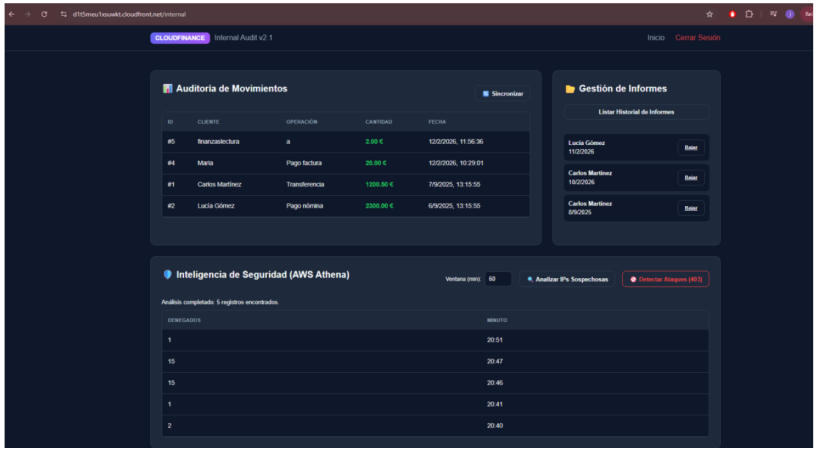


(b) Análisis forense de logs mediante consultas SQL en Amazon Athena

Evidencias de funcionamiento (III): Inteligencia de Seguridad



(a) Identificación de IPs sospechosas y cálculo de Risk Score



(b) Desglose de eventos denegados y patrones de ataque

Valor Diferencial

Integración de lógica heurística en el panel administrativo para transformar logs crudos en decisiones de seguridad accionables.

Conclusiones

- Se implementó una arquitectura AWS **segura por diseño** con controles Zero Trust.
- Control de acceso granular (IAM) + cifrado robusto (KMS) + auditoría centralizada (CloudTrail/CloudWatch).
- Observabilidad consolidada: alarmas inteligentes + dashboard tipo SOC.
- Capacidad de analítica y detección: logs → Athena → reportes cifrados.

Aportación principal

Convertir telemetría cloud en inteligencia de seguridad operativa, demostrable mediante experimentos.

Líneas Futuras

- Automatizar respuesta: integración con AWS Lambda / EventBridge para acciones (bloqueo IP, cuarentena).
- Ampliar detección: modelos ML supervisados y enriquecimiento (GeoIP, reputación, ASN).
- Endurecimiento adicional: WAF, GuardDuty, Security Hub y playbooks de respuesta.

¿Preguntas?

Sistema de Gestión y Análisis de Identidades en AWS bajo una Arquitectura Zero-Trust: Auditoría Continua e IA Heurística

José Jesús Peñate Perdomo

Tutor: *César Cáceres Taladriz*